



Map NIST AI RMF and NIST AI 800-1 into an AI governance compliance checklist — cross-referencing governance, map, measure, and manage functions with dual-use foundation model controls

Computer

Build a student support resource navigator — map basic-needs services, eligibility criteria, FERPA compliance rules, and access workflows into a filterable directory

Computer

Show me how to structure the FERPA consent workflow

Draft the institutional policy section on AI model training

Expand the compliance checklist for NIST AI 800-1 dual-use risks

Below is a practical structure for the FERPA consent workflow, an institutional AI model-training policy section, and an expanded NIST AI 800-1 misuse-risk checklist. This is a product and governance blueprint, not legal advice; counsel should validate it for each institution, jurisdiction, contract, and data flow.

FERPA generally requires signed and dated written consent before personally identifiable information from education records is disclosed, unless a specific exception applies. A valid consent must identify the records, purpose, and recipient or recipient class; oral consent is not sufficient. [¹⁵⁸⁷] ^[1]

FERPA consent workflow

When consent is needed

Use a decision gate before any disclosure outside the student's private workspace.

1. Is the information personally identifiable information from an education record?
2. Is Semester disclosing, transferring, or permitting access to it to another person or entity?
3. Does a documented FERPA exception apply?
Examples may include a properly structured school-official arrangement, transfer to another institution where the student seeks/enrolls, health/safety emergency, audit/evaluation, or studies exception.
4. If no exception applies:
Obtain signed, dated, specific written consent before disclosure.

5. If an exception is asserted:
Record the legal/policy basis, recipient, purpose, data scope, authorizing institution, expiry/review date, and access controls.

Do not use a generic checkbox such as “I agree to share my information.” That is not sufficiently specific for a FERPA disclosure consent.

Student experience

Student selects “Share with Career Center”

- Semester creates a human-readable disclosure summary
- Student reviews the exact records and recipient
- Student signs and dates electronically
- Semester records consent version and audit evidence
- Career Center receives only the approved scope
- Student can view active shares and revoke future access
- Access expires automatically at the selected date
- Revocation stops future disclosure but does not necessarily erase records already lawfully received or retained

Consent screen copy

Share selected information with the Career Center?

Recipient:

Career Center, [Institution Name]

Purpose:

Review your resume and provide career coaching.

Records you are sharing:

- Resume draft
- Selected portfolio artifacts
- Career goals you entered
- Opportunity tracker items you choose

Not included:

- Transcript or grades
- Financial-aid information
- Basic-needs activity
- Accessibility/accommodation information
- Transfer-credit documents
- Private AI conversations
- Club memberships
- Private notes

Access:

Career Center staff assigned to your coaching request

Duration:

Until December 15, 2026, unless you revoke future access earlier.

Your choices:

- Edit what is included
- Change the expiration date
- Cancel
- Sign and share

Consent data model

```
consent_id
tenant_id
student_id
consent_version
signed_at
signature_method
records_categories
field-level scope
purpose
recipient_type
recipient_id or recipient class
legal basis
effective_at
expires_at
revoked_at
revocation_reason, optional
disclosure_log_ids
policy_document_version
terms_snapshot_hash
audit_correlation_id
```

Required workflow controls

- [] Digital signature is attributable to the eligible student.
- [] Consent is signed and dated.
- [] Records are listed in understandable categories and, where possible, fields.
- [] Purpose is specific and understandable.
- [] Recipient is named or a sufficiently specific recipient class is identified.
- [] Scope defaults to minimum necessary data.
- [] Consent is separate from general product terms.
- [] Expiry is required; no indefinite sharing by default.
- [] Student can inspect active, expired, and revoked consents.
- [] Revocation prevents new disclosures going forward.
- [] Every disclosure is logged with actor, recipient, fields, purpose, time, and legal basis.
- [] Recipient access is role-bound, time-limited, and auditable.
- [] If a FERPA exception is used, the system records exception rationale and institution.
- [] Export, correction, deletion, retention, and legal-hold behavior are defined.
- [] Accessibility review confirms keyboard, screen-reader, plain-language, and mobile access.

FERPA's general rule is consent before disclosure of education-record PII, although the regulations include specific exceptions. The institution—not a general-purpose product setting—must determine and document the applicable exception and conditions. ^[1593][1594]

AI model-training policy

The most important policy choice for Semester should be:

Semester does not use student, institutional, or customer production content to train general-purpose AI models by default.

Any deviation should require a separately negotiated agreement, documented legal basis, informed authorization where required, technical segregation, and an explicit opt-in workflow. This stance is easier to explain, safer for institutional procurement, and aligned with the sensitivity of academic, support, and basic-needs data.

Draft policy section

AI Model Training and Data Use

Purpose and scope

This policy governs how Semester uses data in connection with artificial-intelligence features, including model training, fine-tuning, evaluation, retrieval, safety monitoring, quality assurance, and service improvement.

This policy applies to student, faculty, staff, institutional, customer, applicant, partner, and other user data processed through Semester.

Default rule

Semester does not use Customer Data, Student Content, institutional records, private communications, uploaded course materials, support requests, basic-needs activity, mentorship content, accessibility information, or AI conversations to train or fine-tune general-purpose artificial-intelligence models by default.

Semester does not permit AI providers to use such data for their own model training unless an institution has separately authorized that use in writing and the applicable technical, contractual, and legal controls are in place.

Permitted operational uses

Subject to applicable agreements and documented controls, Semester may process the minimum information necessary to:

- Provide a user-requested AI feature.
- Retrieve authorized sources for a grounded answer.
- Detect abuse, fraud, security threats, or policy violations.
- Maintain reliability, diagnose errors, and provide support.
- Evaluate safety, accuracy, accessibility, and quality.
- Generate de-identified, aggregated service metrics.
- Comply with legal obligations.

Semester will limit these uses by purpose, retention, access, and data classification.

Prohibited data uses

Semester will not use the following for general-purpose model training, behavioral advertising, student ranking, or undisclosed profiling:

- Education-record PII.
- Grades, transcripts, course performance, attendance, or disciplinary data.
- Accommodation, disability, health, counseling, or basic-needs information.
- Financial-aid, payment, housing, immigration, or legal information.
- Private mentoring, club, peer-circle, or support conversations.
- Private AI conversation content.
- Institution-provided confidential information.
- Sensitive personal data or inferred sensitive characteristics.
- Content from one tenant to answer another tenant's request.

Optional customer-authorized improvement program

Any optional program involving customer production data must meet all of these conditions:

- Separate written agreement and tenant-level authorization.
- Specific purpose, data categories, model/provider, and duration.
- No enrollment by default.
- Data-minimization and de-identification assessment.
- No use of restricted or highly sensitive data categories.
- Strict tenant segregation.
- Security, privacy, accessibility, and AI-risk review.
- Human oversight and documented evaluation plan.
- Withdrawal process and future-use stop mechanism.
- Clear retention/deletion rules.
- No onward sharing without documented authorization.
- Transparent student/faculty notices where required.

Model provider controls

Semester must maintain a current inventory of AI providers and models, including:

- Provider and model/version.
- Processing location and residency.
- Input/output retention.
- Training and secondary-use terms.
- Security commitments.
- Subprocessors.
- Data deletion mechanism.
- Available safety controls.
- Incident notification obligations.
- Change-notice commitments.

No provider may be enabled for production student or customer content until security, privacy, legal, accessibility, procurement, and AI-governance approval is documented.

Transparency and user control

When AI is used, Semester will provide, where appropriate:

- Notice that AI was used.
- Source, scope, and status labels.
- Applicable course or institutional policy.
- Relevant limitations and human-review guidance.
- A way to report incorrect, harmful, inaccessible, or policy-inappropriate output.
- Controls for eligible AI history, sharing, and deletion.

Governance and enforcement

Semester maintains an AI inventory, risk assessments, evaluation records, incident-response procedures, access controls, change management, and periodic reviews. Material policy violations may result in feature restriction, suspension, customer notification where appropriate, provider escalation, or other corrective action.

Implementation requirements

A policy is credible only if enforced in architecture:

- Tenant-scoped retrieval indexes.
- No cross-tenant vector search.
- Provider contracts with no-training/no-retention terms where available.
- Prompt/output redaction and data-loss-prevention controls.
- Separate environments for production, evaluation, and synthetic test data.
- Role-bound access to AI logs.
- Retention limits for prompts, outputs, and evaluation samples.
- Configurable tenant-level AI enablement and policy controls.
- Provider/model change-approval workflow.
- Deletion propagation to retrieval indexes, caches, and evaluation datasets.
- Audit logs for AI feature use, model/version, source set, policy decision, and safety.

NIST AI 800-1 checklist

Status note: NIST AI 800-1 is listed by NIST as *Managing the Risk of Misuse for Dual-Use Foundation Models*, Second Public Draft (2025). Treat it as voluntary draft guidance rather than a finalized compliance certification, and verify its publication status before citing it in contracts or external compliance claims. [¹⁵⁸⁶][¹⁵⁹⁷]

AI 800-1 focuses on misuse that could cause deliberate harm to individuals, public safety, or national security—such as enabling offensive cyber operations, biological threats, child sexual abuse material, or nonconsensual intimate imagery. Its guidance is most directly aimed at foundation-model developers, but a SaaS application deploying third-party models should adapt the relevant controls to its role. [¹⁵⁸⁸]

Applicability decision

- [] Identify whether Semester develops, fine-tunes, hosts, or merely accesses a foundation model.
- [] Identify model modalities: text, code, image, audio, video, agentic/tool-use.
- [] Identify whether any feature exposes broad public prompting, code generation, external tool use, or other high-risk capabilities.
- [] Identify model provider responsibilities versus Semester responsibilities.
- [] Document why each dual-use control is applicable, partially applicable, or not applicable.
- [] Reassess when adding models, modalities, agents, tools, new data sources, or public features.

Governance and accountability

- [] Assign an executive AI-risk owner.
- [] Assign a named technical owner for each deployed model/provider.
- [] Create an AI risk committee with security, privacy, legal, accessibility, product, trust-and-safety, and institutional representatives.
- [] Maintain a model/system inventory with versions, owners, use cases, tenants, data types, integrations, and risk tiers.
- [] Define AI risk appetite and unacceptable-use categories.
- [] Establish an escalation path for dual-use, abuse, security, safety, copyright, privacy, and student-harm incidents.
- [] Require approval before enabling model tool use, code execution, external actions, or elevated automation.
- [] Maintain evidence of training for operators, developers, moderators, support teams, and customer administrators.
- [] Review provider terms, safety controls, security posture, retention, training, incident notice, and deletion commitments.
- [] Run periodic governance reviews and publish an appropriate transparency summary.

Misuse threat modeling

- [] Identify plausible deliberate misuse by students, outsiders, insiders, malicious prompt authors, compromised accounts, and third-party integrations.
- [] Assess misuse through text, code, image, audio, video, uploaded documents, API access, agents, browser tools, and export pathways.
- [] Model prompt injection, jailbreaks, indirect prompt injection, data exfiltration, social engineering, impersonation, malware generation, fraud, harassment, sexual exploitation, dangerous instructions, and unauthorized system actions.
- [] Identify vulnerable populations and high-impact contexts.
- [] Identify tool-use risks: email, calendar, LMS, SIS, file storage, payment, messaging, or external API actions.
- [] Map attack paths from model output to real-world harm.
- [] Define severity levels, mitigations, residual risk, and stop/disable criteria.
- [] Re-run threat models after material feature, provider, model, integration, or policy changes.

Model capability and access assessment

- [] Record model capabilities and known limitations by version.
- [] Test relevant misuse capabilities before deployment and on material change.
- [] Test code-generation, cyber-abuse, dangerous-instruction, impersonation, privacy, data-exfiltration, and harmful-content boundaries as applicable.
- [] Test multimodal input/output if files, images, audio, or video are supported.
- [] Test tool-use and agent behavior separately from text-only behavior.
- [] Implement risk-tiered access: no access, limited access, authenticated access, verified access, privileged access, or sandbox-only access.
- [] Enforce rate limits, quotas, concurrency caps, and abuse detection.
- [] Require stronger identity and authorization controls for higher-risk capability.
- [] Remove or gate capabilities that cannot be controlled to an acceptable residual risk.

Safeguards and defense in depth

- [] Apply policy controls before model invocation.
- [] Use allowlisted tools, destinations, actions, and data sources.
- [] Enforce least privilege for model-connected tools.
- [] Require user confirmation before external writes or consequential actions.
- [] Use content safety classifiers and policy filters before and after generation.
- [] Add prompt-injection defenses for retrieved content, uploads, web content, and third-party integrations.
- [] Isolate tool execution; sandbox code; restrict network and filesystem access.
- [] Scan uploads and generated files for malware or dangerous payloads.
- [] Redact or block unnecessary sensitive data before provider calls.
- [] Limit output detail for content that may meaningfully facilitate harm.
- [] Implement account, device, IP, and behavioral abuse controls proportionate to risk.
- [] Use kill switches, feature flags, model/provider rollback, and emergency disable.

Evaluation, testing, and monitoring

- [] Maintain a documented evaluation plan per AI feature and model version.
- [] Test safety, misuse, privacy, bias, accessibility, grounding, hallucination, prompt injection, data leakage, and tool-use behavior.
- [] Include adversarial/red-team tests relevant to the user population and feature.
- [] Test misuse scenarios using synthetic or approved test data—not student records.
- [] Establish acceptance thresholds and launch-blocking criteria.
- [] Monitor abuse signals, blocked requests, override rate, false positives, false negatives, safety reports, appeals, incidents, and time to response.
- [] Monitor model drift and re-evaluate after provider/model changes.
- [] Review disproportionate harms and accessibility impacts.
- [] Preserve evaluation evidence, known limitations, and remediation decisions.

Incident response and transparency

- [] Maintain AI-specific incident categories and severity definitions.
- [] Maintain a 24/7 escalation path only if it is actually staffed and tested; otherwise disclose the true support model.
- [] Provide a user report mechanism for harmful, unsafe, incorrect, biased, inaccessible, or policy-violating output.
- [] Triage incidents using defined owners, SLAs, and evidence controls.
- [] Restrict, disable, or roll back affected capabilities when risk exceeds threshold.
- [] Notify affected customers/users/regulators when required by law, contract, or incident policy.
- [] Conduct root-cause analysis and corrective-action tracking.
- [] Update evaluations, prompts, policies, training, and product controls after incidents.
- [] Publish appropriate transparency/change information without revealing exploitable details.

Basic-needs resource navigator

A filterable directory should be a **content and routing system**, not a central database of student hardship.

Directory schema

Field	Example
Resource name	Emergency grocery support
Category	Food and nutrition
Provider type	Institution office / verified community partner / public benefit
Owner	Basic Needs Center
Status	Institution verified
Eligibility	Currently enrolled students; check current policy
Documentation	Student ID; appointment may be required
Cost	Free
Access type	Walk-in, appointment, online request
Location / service area	Student Union, Room 120 / remote option
Hours	Mon–Fri, 9 AM–5 PM
Languages	English, Spanish, interpretation available
Accessibility	Step-free entrance; remote intake option
Privacy note	Browsing does not notify staff; referral shares only selected details
Emergency note	Not an emergency service; use official emergency route for immediate danger
Official source URL	Institution resource page
Last reviewed	2026-09-15

Field	Example
Review due	2026-12-15
Content owner	Named office/role
Report issue	Broken link/outdated-info form

Student filters

Need category
 Urgency: today / this week / planning ahead
 Eligibility group, only if voluntarily selected
 Cost: free / low cost / insurance accepted
 Location and transit access
 Remote/hybrid availability
 Hours: evening/weekend/open now
 Language
 Accessibility features
 Appointment needed
 Documentation required
 Institutional or community provider

Access workflow levels

Browse:
 No login or no staff-visible record where feasible.

Save:
 Private student bookmark/checklist; no staff notification.

Prepare:
 Student sees documents, eligibility, hours, questions, and official link.

Request:
 Student explicitly selects a named recipient and shares only required fields.

Refer:
 Receiving office accepts/declines assignment and updates limited referral status.

Close:
 Student receives outcome options; sensitive details remain in the official service system, not the general Semester platform.

Recommended next artifacts

Build these as controlled, versioned documents and system modules:

1. FERPA consent and disclosure policy, plus the exact consent-screen component library.
2. AI Model Training and Data Use Policy, reviewed by privacy, security, legal, and institutional customers.

3. AI 800-1 applicability and risk register for every AI feature/model.
4. AI incident-response runbook, abuse taxonomy, and kill-switch/rollback procedure.
5. Basic-Needs Navigator content-governance policy, directory schema, and role/permission matrix.
6. Institution-specific escalation directory and emergency-services boundary language.
7. Data-processing inventory that connects every UI field to purpose, owner, retention, and access control.

The guiding standard is: a student should never have to trade privacy for help, and an institution should never have to trade safety for usefulness.

**

1. <https://studentprivacy.ed.gov/frequently-asked-questions>
2. [https://studentprivacy.ed.gov/sites/default/files/resource_document/file/FERPA Exceptions HANDOUT portrait 0.pdf](https://studentprivacy.ed.gov/sites/default/files/resource_document/file/FERPA%20Exceptions%20HANDOUT%20portrait%200.pdf)
3. <https://csrc.nist.gov/Projects/cosais/use-cases>
4. <https://studentprivacy.ed.gov/faq/does-ferpa-permit-schools-disclose-any-and-all-education-records-student-another-school-where>
5. <https://pages.nist.gov/NIST-Tech-Pubs/DRAFT.html>
6. <https://www.nist.gov/news-events/news/2025/01/updated-guidelines-managing-misuse-risk-dual-use-foundation-models>
7. <https://studentprivacy.ed.gov/ferpa>
8. <https://airc.nist.gov/technical-reports/>
9. <https://studentprivacy.ed.gov/faq/what-must-consent-disclose-education-records-contain>
10. <https://www.nist.gov/news-events/news/2024/07/departments-commerce-announces-new-guidance-tools-270-days-following>
11. <https://studentprivacy.ed.gov/faq/who-responsible-obtaining-written-consent-parent-or-eligible-student-school-or-community-based>
12. <https://studentprivacy.ed.gov/faq/prior-written-consent-parent-or-eligible-student-required-disclose-information-community-based>
13. <https://csrc.nist.gov/csrc/media/Projects/cosais/documents/NIST-Overlays-SecuringAI-concept-paper.pdf>
14. <https://studentprivacy.ed.gov/content/disclosure>
15. <https://studentprivacy.ed.gov/privacy-and-data-sharing>